

Western Governors University

Legal Issues in Information Security

D828

Jessie Soto

QEN Task 1: Information Security Policy Analysis

Telemedica

A. Organizational Summary

TeleMedica is a leading telehealth platform designed to bridge the gap between patients and healthcare providers through secure, remote consultations. The organization's goal is to protect client data by applying the CIA triad while maintaining compliance with applicable laws and regulations. Telemedica handles both data at rest and data in transit, including sensitive health information that requires strong security and privacy protections.

B. Organizational Frameworks

Organizational Framework 1: NIST CSF

The foundational framework used is the NIST Cybersecurity Framework (CSF). The organization addresses each of its core functions within its security policy. Beginning with the Identify function, the data protection and privacy policy outlines a risk assessment process that defines the types of data handled. This is followed by a risk management strategy focused on protecting information by encrypting both data at rest and data in transit.

Organizational Framework 2: NIST RMF

In addition to the NIST CSF, the organization's policies align with the NIST Risk Management Framework (RMF). This framework is a high-level, seven-step process used to manage risks associated with its telehealth systems. During the Monitor step, TeleMedica utilizes a security operations center (SOC) team to review network logs on a weekly basis and

employs automated monitoring systems to detect unusual activity on critical infrastructure (TeleMedica, 2026).

C. Organizational Security Standards

Security Standard 1: NIST SP 800-53

The first security standard that informed TeleMedica's policy is NIST SP 800-53, specifically control AT-2 (Literacy Training and Awareness). This control requires organizations to provide foundational security awareness training to all information system users (CSF Tools, n.d.). TeleMedica aligns with this standard within its Acceptable Use Policy, which mandates that "employees complete mandatory training through TeleMedica's learning management system" to ensure a secure operational environment (TeleMedica, 2026).

Security Standard 2: ISO/IEC 27001

The second security standard that informed TeleMedica's policy is ISO/IEC 27001, specifically Annex A.9 (Access Control). This standard focuses on ensuring that system access is limited to authorized users and based on business requirements. Within the Access Control Policy section, TeleMedica aligns with this standard by stating that "access to the patient information systems is restricted based on job function, adhering to the least privilege principle" (TeleMedica, 2026).

D. Organizational best practices

Best Practice 1: Secure Data Transmission via VPN

The first best practice involves TeleMedica ensuring that all data moving between its internal systems, its sister company MediCom GmbH, and third-party providers is transmitted over a Virtual Private Network (VPN) (TeleMedica, 2026). This is considered effective because it aligns with NIST SP 800-77 (Guide to IPsec VPNs). VPNs protect data by creating an encrypted tunnel that preserves the confidentiality and integrity of sensitive health information as it traverses untrusted networks (National Institute of Standards and Technology, 2020).

Best Practice 2: Secure Data Destruction

The second best practice occurs when sensitive data is no longer required; TeleMedica utilizes an enterprise-approved data destruction tool to permanently delete the information from the system (TeleMedica, 2026). This practice follows the NIST SP 800-88 (Guidelines for Media Sanitization). Utilizing professional destruction tools is a critical safeguard to ensure that "data-at-rest" cannot be recovered by unauthorized parties after it is no longer needed (National Institute of Standards and Technology, 2014).

Best Practice 3: Quarterly Access Audits

The third best practice requires the IT security team to conduct quarterly audits of all access privileges (TeleMedica, 2026). This is a requirement of ISO/IEC 27001 (Control A.9.2.5), which mandates the regular review of user access rights. Frequent auditing is effective because it helps identify unnecessary privileges retained by employees that are no longer needed for their current job functions.

E. Legal consideration for the organization

State Level-Law: Massachusetts 201 CMR 17.00

The Massachusetts 201 CMR 17.00 Standards for the Protection of Personal Information mandate that any business handling the personal information of Massachusetts residents must maintain a written information security program (WISP) and implement technical security measures to protect sensitive data (Massachusetts Office of Consumer Affairs and Business Regulation, 2017).

TeleMedica meets these compliance requirements through its security policies related to hardware and monitoring. The policy mandates that only IT-issued encrypted USB drives may be used and that all removable media must be scanned for malware before use (TeleMedica, 2026).

National Law: federal information security management (FISMA)

The federal information security management (FISMA) act is for organizations who work with federal data to have continuous monitoring and regular auditing of information systems (zyBooks, n.d.). Although telemedical handles data within the medical field, they

do follow the FISMA requirements with respects to the continuous monitoring by their security operations center and the audits for user access level.

International Law: GDPR

The GDPR is a “privacy by design” law created for countries within the European union (zyBooks, n.d.). With their sister company based in Berlin, Germany, they maintain the standings of the GDPR law by protecting data in transit using VPN to their sister company.

Industry-Specific Law: HIPPA

The industry specific law telemedica must follow is the HIPPA law. They demonstrate and meet the requirements of HIPPA’s breach notification rule. Although there isn’t specified steps in the recovery process, they use the DACER methodology which is a structured plan to handle data breaches.

F. Organization Non-Compliance

Organizational Non-Compliance: HIPPA security Rule.

The organization is not in full compliance with the HIPPA security Rule. For data in transit, they are required to use TLS 1.2 or higher to secure data in transit (Censinet, n.d.).

Telemedica is currently using SSL.v2 protocol which is an outdate and unsecure protocol.

Organizational Non-Compliance: NIST SP 800-63

Telemedica is not in compliance with the NIST SP 800-63 password MFA recommendations. They recommend that usings a 2 factor authentication vs just a single password.

Organizational Non-Compliance: HIPPA Retention Requirements

Telemedica is not in compliance with the HIPPA data retention requirements. They are required to keep data for a minimum of 6 years and they do not have a specified data retention time (Alder, 2026).

G. Recommended Organization Remediation

Remediation 1: HIPPA security rule

To correct the non-compliance with the HIPAA Security Rule, TeleMedica must replace the outdated and insecure SSL 2.0 protocol with a modern, secure encryption method such as TLS 1.2 or higher. Transport Layer Security (TLS) provides a significantly more robust form of encryption for data-in-transit (Duò, 2025).

Remediation 2: NIST SP 800-63

To establish a more secure environment, TeleMedica should follow the NIST SP 800-63 guidelines by implementing Multi-Factor Authentication (MFA). Requiring a second form of verification ensures that even if a password is compromised, unauthorized parties cannot gain access.

Remediation 3: HIPPA Retention Requirements

To meet HIPAA retention requirements, TeleMedica must develop a data retention plan and policy. At a minimum, the organization is required to store relevant health and security documentation for at least six years.

References:

TeleMedica. (2026). *Information security policy*

zyBooks. (n.d.). *Section 3: [Core functions and categories]. In WGUD828v1, Chapter 7.* Retrieved February 20, 2026, from [Section 7.3 - D 828: Legal Issues in Information Security | zyBooks](#)

National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0* (NIST Cybersecurity White Paper No. CSWP 29). [The NIST Cybersecurity Framework \(CSF\) 2.0](#)

zyBooks. (n.d.). *Section 3: [The Health Insurance Portability and Accountability Act (HIPAA) In WGUD828v1, Chapter 10.* Retrieved February 21, 2026, from [Section 10.3 - D 828: Legal Issues in Information Security | zyBooks](#)

CSF Tools. (2023). *NIST SP 800-53, Revision 5.* Retrieved February 21, 2026, from [NIST SP 800-53, Revision 5 - CSF Tools](#)

CSF Tools. (n.d.). *AT-2: Literacy training and awareness.* Retrieved February 22, 2026, from [AT-2: Literacy Training and Awareness - CSF Tools](#)

National Institute of Standards and Technology. (2020). *Guide to IPsec VPNs* (NIST Special Publication 800-77 Rev. 1). U.S. Department of Commerce. [Guide to IPsec VPNs | NIST](#)

National Institute of Standards and Technology. (2014). *Guidelines for media sanitization* (NIST Special Publication 800-88 Rev. 1). U.S. Department of Commerce. [NIST Special Publication 800-88, Revision 1: Guidelines for Media Sanitization | NIST](#)

Holloway, D. (2025, September 1). *ISO 27001 – Annex A.9: Access control (2013).* ISMS.online. Retrieved February 22, 2026, from [ISO 27001 – Annex A.9: Access Control | ISMS.online](#)

Massachusetts Office of Consumer Affairs and Business Regulation. (2017). *201 CMR 17.00: Standards for the protection of personal information of residents of the Commonwealth.* Mass.gov. Retrieved February 22, 2026, from [201 CMR 17.00: Standards for the protection of personal information of residents of the Commonwealth | Mass.gov](#)

zyBooks. (n.d.). *Section 16: [Federal Information Security Management Act (FISMA) Section 10.16 - D 828: Legal Issues in Information Security | zyBooks*

Censinet. (n.d.). *HIPAA encryption rules for data in transit*. Retrieved February 22, 2026, from [HIPAA Encryption Rules for Data in Transit | Censinet, Inc.](#)

Alder, S. (2026, January 5). *HIPAA retention requirements*. *HIPAA Journal*. Retrieved February 22, 2026, from [HIPAA Retention Requirements - 2026 Update](#)

Duò, M. (2025, October 1). *TLS vs SSL: What's the difference? Which one should you use?* Kinsta. Retrieved February 22, 2026, from [TLS vs SSL: What's the Difference? Which One Should You Use?](#)